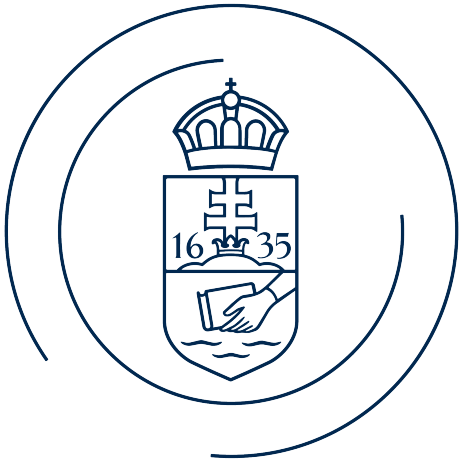


ELTE
EÖTVÖS LORÁND
UNIVERSITY

1010110100101010101110101101001010101011101110101101001010101000

Cybersecurity basics

Information gathering

OSINT, digital footprint, network scanning

Password Security

What you will learn...



- What is OSINT?
- What is the type of information that can be found online?
- What is the difference between active and passive information gathering?
- Why is DNS security important?
- How is the security and privacy of individuals different from companies?
- How can you protect yourself as an individual?
- How can companies protect against exposing too much information?
- What information can hackers abuse?

The dilemma of reasonable security

- Having something 100% secure is easy.
- Having something 100% secure while providing good service is impossible.
- The challenge is drawing the line so that systems are secure, but also functional.

Active vs. passive methods

When talking about information gathering the target is either an individual with accounts in various information systems or an organization with a set of information systems of its own. An organization typically has several individual members.

Definition: Passive information gathering

The process of collecting information **without directly interacting with the target**, relying on publicly available sources and indirect methods.

Definition: Active information gathering

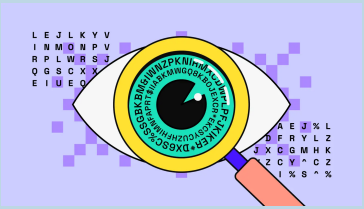
The process of collecting information by **directly interacting with the target** system, network, or organization

Comparison

Passive	**Active**
No direct interaction with the target	Direct interaction with the target
Very low risk of detection	Can be detected by well configured monitoring
Examples include Subdomain enumeration, Google Dorking, Social media and darknet monitoring	Examples including network scanning and vulnerability assessment
Purpose is stealthy initial recon	A more focused, deeper analysis of security

Passive enumeration

What is OSINT?



Open-Source Intelligence (OSINT) refers to the process of collecting, analyzing, and leveraging publicly available information to gain insights about a target, organization, or situation. This information is gathered from open and accessible sources, such as websites, social media platforms, online forums, government publications, news outlets, and publicly available databases.

What is possible?

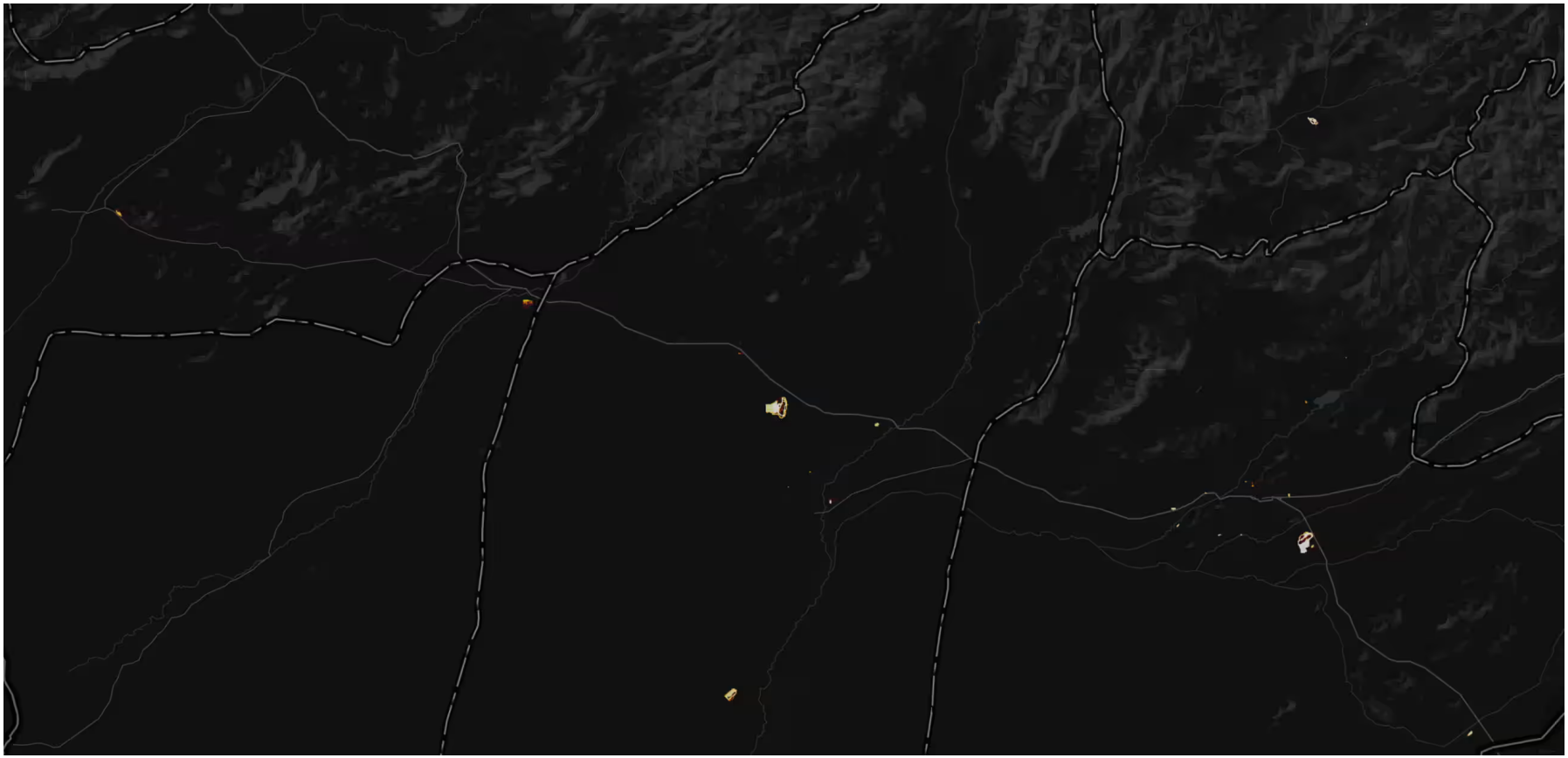
Short answer, everything.

Strava



Popular fitness application Strava published anonymized, aggregated usage GPS data globally. Several parties noted that this revealed sensitive information implicitly.

Strava heatmap in Afghanistan's Helmand province



What is possible?

Tickets and badges



Uploading pictures to social media where QR codes, barcodes or other visual information storage formats can be dangerous. It can easily be possible to reconstruct the sensitive information coded into them.

What is possible?

Search engines are always paying attention



The internet is a place where information is always continuously flowing. Search engines work based on proactive information gathering and index everything they can find.

Example dorks on Google hacking database

2024-07-04	intitle:index of /etc/ssh
2024-05-13	"START test_database" ext:log
2024-05-13	"Header for logs at time" ext:log
2024-05-01	intext:"dhcpd.conf" "index of"
2024-05-01	site:uat.* * inurl:login

OSINT techniques

Example techniques

In the following sections we will take a look at some example techniques of OSINT. This list is far from comprehensive, there are endless possibilities to explore.

Reminder

When working with OSINT, the goal is always to gather information about a target, a person or an organization, without interacting with them.

Balancing act

From the defensive perspective, remember the dilemma of reasonable security. It is easy to not expose anything at all, but for most organizations, and even individuals, this is not a viable option.

Google dorking

Google dorking is a technique that uses advanced search operators in Google to uncover sensitive information that may not be intended for public access. By crafting specific search queries, it is possible to locate files, passwords, email lists, sensitive documents, or even vulnerable systems indexed by search engines. For example, queries like filetype:pdf site:example.com can find all PDFs on a website, or intitle:"index of" password can expose unprotected directories.

Advanced search operators

Operator	Description	Example
Quotation Marks (")	Finds an exact phrase.	"artificial intelligence"
OR	Finds results containing either term.	cat OR dog
AND	Finds results containing both terms.	python AND programming
NOT	Excludes results containing a term.	technology NOT software
Wildcard (*)	Replaces any word or phrase.	steve * jobs
Site:	Limits results to a specific website.	site:wikipedia.org
Related:	Finds related websites.	related:google.com
in title:	Finds results with a specific word in the title.	in title:how to learn programming
Inurl:	Finds results with a specific word in the URL.	inurl:blog
Intext:	Finds results with a specific word in the content.	intext:machine learning
Filetype:	Finds results of a specific file type.	filetype:pdf
Cache:	Finds the cached version of a webpage.	cache:google.com
Define:	Finds the definition of a word.	define:algorithm
Around(x):	Finds results with two words within x words of each other.	around(5) artificial intelligence machine learning
Daterange:	Limits results to a specific date range.	daterange:20230101:20231231
Source:	Finds results from a specific source in Google News.	source:bbc.com

Google hacking database

There are several databases where dorks are collected such as **https://www.exploit-db.com/google-hacking-database**

Demo

Let's try it live!

Diving into social media

People are often very careless with what they share publicly, even though most social media sites offer options to control the scope of information. Social media can also reveal much more than just the direct information you post.

Exifdata

EXIF data (short for Exchangeable Image File Format data) is metadata embedded within digital photos and other media files, providing information about the image or file. This data is automatically generated by cameras, smartphones, or other devices when a photo or video is captured. This metadata famously includes GPS coordinates.

Leaks and the dark web

There are successful cyberattacks every day. Sometimes they are targeted with a very specific purpose, sometimes attackers hit whoever they can. When attackers loot large databases of data, they often offer them for sale in underground marketplaces. Services exist to check whether our data is being sold out there.

HaveIBeenPwned

Service to verify whether usernames associated with a particular email address can be found in known breaches. `https://haveibeenpwned.com/`

Pentester.com

Service to scan for any exposure associated with your account and automated to contact data brokers for a transaction fee. `https://pentester.com/`

What types of information can be valuable?

Information gathering objectives

- Critical access information such as passwords, cryptographic keys
- Sensitive information such as usernames, personal information such as family, pets, work, nicknames etc. that can be used for candidates for password bases and also as pretext for social engineering
- Technical information about an organization's infrastructure (i.e. software used, policies, network)
- List of assets, list of system integrations, 3rd party vendors etc.
- One key example: subdomains

Technical information gathering

Fingerprinting and infrastructure

- When something is connected to the internet, it can be queried and indexed similarly to how search engines work.
- This means all devices, regardless of intentional or unintentional.
- Search engines such as Shodan are an excellent examples for this: they have their own filters and operators similar to Google.
- We will not dive deep into this, but let us see an example:
  ("webcam 7" OR "webcamXP")
  http.component:"mootools" -401

Important takeaway: you do not have to be important or interesting to be a victim of a cyberattack! It is enough to be vulnerable.

Subdomain enumeration

Different functionalities for an organization are often available under different subdomains. A subdomain is handled at the DNS level. Knowing all the available subdomains increases the attack surface tremendously for attackers.

Subdomain enumeration at the DNS level - Zone transfer

A DNS Zone Transfer vulnerability occurs when a DNS server allows unauthorized users to request and receive the entire DNS zone file, which contains information about domain names and their corresponding IP addresses. This information can provide attackers with valuable details about a target network, such as subdomains, IP addresses, and internal network structure, which could aid in further exploitation. Properly securing DNS servers by restricting zone transfer requests and implementing access control mechanisms can prevent this vulnerability.

Subdomain enumeration by bruteforce

Although not very elegant, it can be an effective way of obtaining valid subdomains to run bruteforce scans. This means having a pre-compiled list of likely domain names and request each one.

- admin.elte.hu - Does not exist
- secret.elte.hu - Does not exist
- neptun.elte.hu - Response

Subdomain enumeration by other means

There are a number of techniques that can be used to perform subdomain enumeration. Some additional examples:

- Google dorking: use advanced operators to narrow down results.
- Public transparency logs: services relying on the SSL/TLS certificate system revealing the names of the domains certificates were issued for.
- Crawl historical data for subdomains used in the past for known websites.
- Parse and analyze javascript and other frontend files for domain names.
- Parse social media and other public resources.

Service enumeration

With a list of hosts available (both IP addresses and domain names/virtual hosts) enumeration enters the service enumeration phase. The goal of service enumeration is to get a sense of the network services available and accessible on a set of network connected hosts. Service enumeration is almost always an active method.

Networking basics

- Network connected machines communicate with the IP protocol, which controls how data packets are delivered on the network.
- The two most common protocols built on top of it are TCP and UDP.
- TCP is more structured and reliable, while UDP has no such features but is generally faster.
- Network communication utilizes the concept of ports. A port is a communication endpoint in a computer network that allows different types of services and applications to communicate over a network. A port is either closed (there is nothing there) or open (expecting incoming communication).

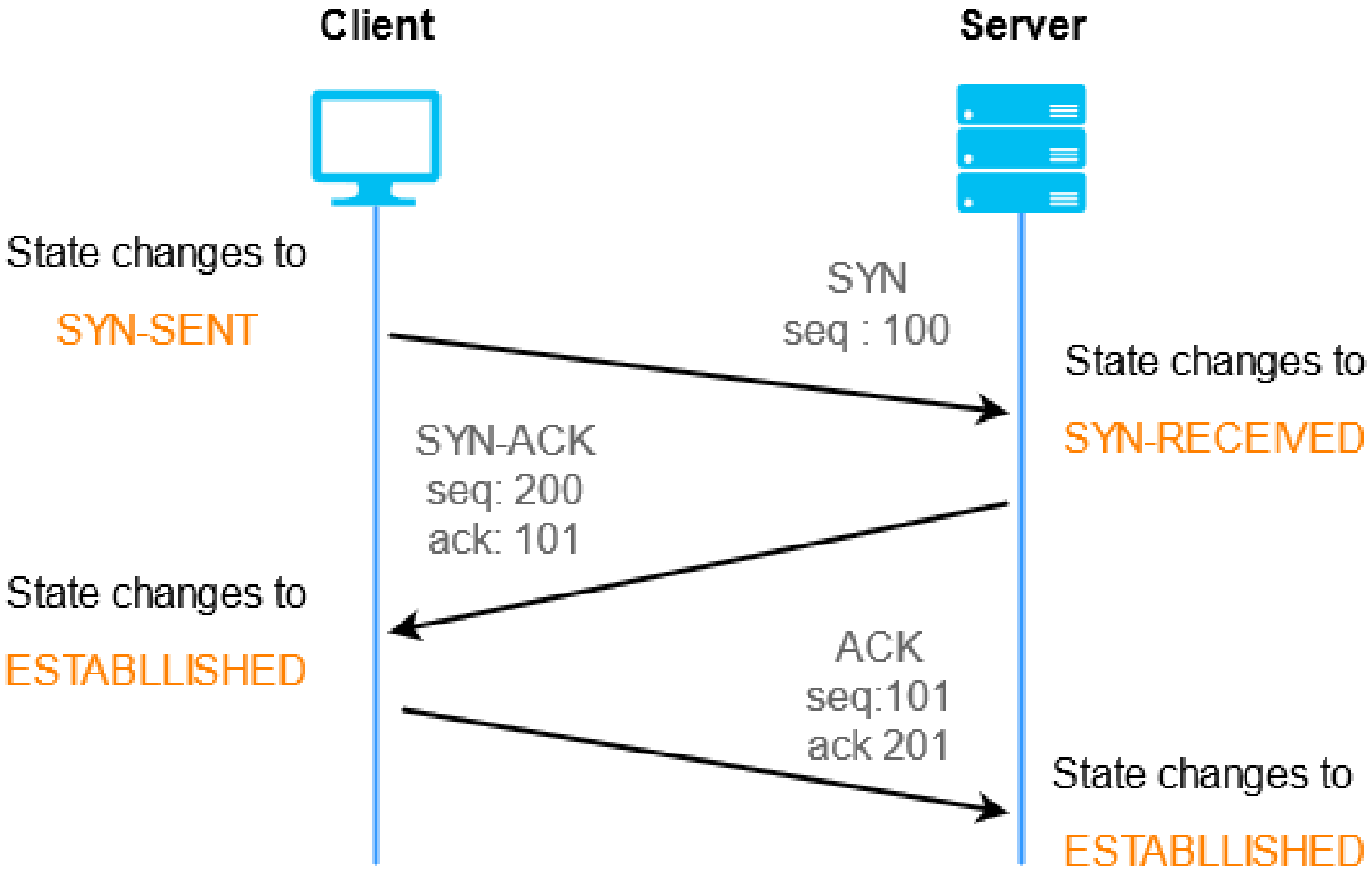
Goals of service enumeration

- The initial goal of service enumeration is to find open ports.
- The second goal of service enumeration is to determine which services are available at the open ports.
- The third goal is to gather any additional information (e.g. software version or operating system)

For this, the most widely accepted tool is nmap. These goals are achieved by sending data packets to the target host and observing the responses received.

TCP 3-way handshake example

Nmap performs the handshake and if the SYN-ACK response is received for a particular port, it can be concluded that the port is open. There are several more nuanced scan techniques too that are out of scope for us.



Cascading enumeration

Information gathering is a step-by-step process.

- Attackers first compile a list of IP addresses and/or subdomains associated with the target organization. This is possible using subdomain enumeration techniques.
- Then, service enumeration is performed on these assets. This reveals the list of open ports and listening services that are accessible. A tool like nmap can typically be used for this task.
- Once the list of serices is available, another round of information gathering begins, this time more focused and technology based.
- The goal of this is to find potential vulnerabilities that enable a threat scenario, an attack avenue.

Enumerating different technologies

Once the particular technology used is identified, information gathering becomes focused on that.

- If a database is found, database specific issues are tested for.
- If an SMB share is found, SMB specific issues are tested for.
- If a web server is found, web specific attack techniques are tested for.

Example - Web server

Web enumeration goals

- Try and find all available virtual hosts.
- Try and find all web content including potentially unlinked paths or files.
- Try and identify all web frameworks used.
- Try and identify all 3rd party components used.
- Try and find the exact version number of all frameworks and components used and any publicly known vulnerabilities used in them.
- Analyze the website logic to find vulnerabilities in custom code used developed.
- Analyze configuration of the website to pipoint any insecure settings that can be abused.

Public vulnerabilities

Responsible disclosure

The flow of responsible disclosure is as follows:

- Researcher finds security issue in software.
- Researcher contacts vendor with details of issue.
- Vendor fixes vulnerability and releases an update.
- After a grace period, everyone hopefully updates to a secure version. The researcher can release technical information. The vulnerability received a CVE-identifier (Common Vulnerabilities and Exposures).
- CVE details are then available publicly.

Public vulnerabilities

Looking up CVEs

These databases storing this public information are available to anyone. If the exact version of software can be determined, it is possible to check for vulnerabilites associated with it. Example website: `https://www.cvedetails.com/`. This is one other reason why updating security patches is important.

Public vulnerabilities

CVSS scores

Not all vulnerabilities are equally problematic. CVSS (Common Vulnerability scoring system) is a scoring system that assigns a value between 0.0 and 10.0 to vulnerabilities. There are also categories to describe this in a more intuitive way.

CVSS scores

Rating	CVSS Score
None	0.0
Low	0.1-3.9
Medium	4.0-6.9
High	7.0-8.9
Critical	9.0-10.0